Informe de pruebas de seguridad: Sprint 9

Proyecto: Perfumería Victoria (tienda en línea de perfumes) · **Marco:** OWASP Top 10 (2025) · **Fecha:** 13 de octubre de 2026 · **Ticket:** SFTWRKEY-412

1. Resumen ejecutivo

El Sprint 9 cerró los riesgos que el informe del Sprint 8 dejó abiertos y las cuatro verificaciones pendientes. **La matriz ya no tiene riesgos críticos ni altos abiertos.** Las funciones nuevas del sprint (vista previa para redes, sitemap) se revisaron con la misma matriz y entraron con sus pruebas.

Resultado	Sprint 8	Sprint 9
Riesgos evaluados en la matriz	45	50
Riesgos en `Pasa`	37	47
Riesgos abiertos	3 (1 crítico, 2 medios)	2 (medios)
Verificaciones pendientes	4	0
Vulnerabilidades en dependencias (frontend, backend)	0, 0	0, 0 (una crítica nueva apareció y se corrigió)

Riesgo residual: dos riesgos medios. SEC-33 (contraseñas de 6 caracteres) se cierra al pasar a `main` la política de SFTWRKEY-409, que hoy está en `staging`. SEC-50 (tres cuentas de clientes de prueba con contraseña pública en producción) se cierra borrándolas o cambiándoles la contraseña. Ninguno da acceso de administrador.

2. Riesgos cerrados en el sprint

ID	Riesgo	Severidad	Tarea	Evidencia
SEC-30	Administrador `admin@luxor.com` con contraseña `123456` publicada en el repo	Crítica	SFTWRKEY-407	El seed toma la cuenta de `ADMIN_EMAIL` y `ADMIN_PASSWORD` (Render) y reemplaza la contraseña si ya existía. Probado con PostgreSQL real; en producción el hash guardado ya no corresponde a `123456`
SEC-36	Login con Google: tokens falsos, reutilizados o de correos no verificados	Alta	SFTWRKEY-411	6 casos en `security.sprint9.test.js`. En producción Google está apagado (sin `GOOGLE_CLIENT_ID`) y `POST /auth/google` responde 503
SEC-29	Abuso del checkout de invitado (tarjetas robadas, precio manipulado)	Alta	SFTWRKEY-410	Rate limit y bloqueo tras 3 rechazos (este último faltaba y se implementó); el precio sale siempre de la base. `security.guestCheckout.test.js`, `declineGuard.test.js`
SEC-32	`/register` sin límite de intentos	Media	SFTWRKEY-408	6 registros por hora por IP, el 7.º responde 429 y queda como alerta (`security.config.test.js`)
SEC-24	Prompt injection contra el chatbot	Media	SFTWRKEY-411	10 de 10 intentos rechazados contra Groq en producción (evidencia) y `test_seguridad_sprint9.py`
SEC-44	Caída del proveedor del LLM	Media	SFTWRKEY-411	Se encontró una falla real (ver sección 3) y se corrigió
SEC-05	La interfaz de admin visible para un cliente	Baja	SFTWRKEY-422, 411	Rutas protegidas por rol en el frontend; con token de cliente las rutas de admin responden 403; en producción sin token o con JWT falso responden 401

El detalle de las pruebas manuales en producción está en anexos/PRUEBAS_MANUALES_SPRINT9.md.

3. Hallazgos nuevos del sprint

ID	Hallazgo	Severidad	Estado
SEC-44	Durante la prueba de SEC-24, Groq limitó las peticiones y el chatbot respondió **500**; además, el proveedor de Ollama no tenía timeout	Media	Corregido: `/chat` corta a los 45 s, Ollama a los 30 s y responde un mensaje amable
SEC-49	`proxy-addr` (dependencia de Express) permitía suplantar la IP con `trust proxy` (GHSA-jqcg-44mw-7w3h), lo que habría permitido saltarse el rate limit por IP	Alta	Corregido: dependencia actualizada, `npm audit` en 0
SEC-46	Vista previa para redes (`api/product-preview.ts`): HTML inyectado desde los datos del producto	Media	Verificado: todo se escapa (`seo.test.tsx`)
SEC-47	Funciones de Vercel: el `id` de la URL se usa para consultar el backend (SSRF, recorrido de rutas)	Media	Verificado: `id` validado y host fijo (`seo.test.tsx` , `sitemap.test.ts`)
SEC-48	Indexación de páginas privadas por buscadores	Baja	Verificado: `robots.txt` y `noindex`
SEC-50	Las cuentas de prueba `juan@` , `maria@` y `carlos@luxor.com` siguen en producción con la contraseña `test123` , porque se crearon antes de SFTWRKEY-407	Media	**Abierto**

4. Pruebas automáticas agregadas

Archivo	Pruebas	Riesgos
`backend/security.sprint9.test.js`	7	SEC-05, SEC-36
`backend/security.guestCheckout.test.js`	5	SEC-29
`backend/services/declineGuard.test.js`	3	SEC-29
`backend/security.config.test.js` (rate limit de `/register`)	12	SEC-32
`backend/chatbot/tests/test_seguridad_sprint9.py`	23	SEC-24, SEC-44
`src/components/routing/ProtectedRoute.test.tsx`	10	SEC-05
`src/seo/seo.test.tsx`	16	SEC-46, SEC-47, SEC-48
`src/seo/sitemap.test.ts`	9	SEC-47, SEC-48

Totales del proyecto al cierre: 317 pruebas de backend, 113 de frontend y 97 del chatbot, todas en verde. El CI corre todas en cada push a `main` , además de las pruebas de integración y regresión contra PostgreSQL.

5. Riesgos que quedan y recomendaciones

Riesgo	Recomendación
SEC-33: contraseñas de 6 caracteres	Pasar a `main` la política de SFTWRKEY-409 (mínimo 12 caracteres) y alinear los formularios del frontend, que todavía validan 6
SEC-50: cuentas de prueba con contraseña pública en producción	Borrar las tres cuentas o cambiarles la contraseña; el seed ya no las vuelve a crear
SEC-35: JWT en `localStorage` (aceptado)	Migrar la sesión a una cookie `httpOnly` en un sprint futuro
Login con Google apagado en producción	Al cargar el id de cliente OAuth en Vercel y Render, repetir los pasos 2 y 4 de SEC-36 en producción

Riesgo	Recomendación
Base de datos del plan gratuito de Render	Vence el 6 de noviembre de 2026; respaldarla o recrearla antes para no perder pedidos ni cuentas

6. Anexos

- Matriz OWASP, con las 50 filas y su estado.
- Pruebas manuales del Sprint 9 (SEC-05, SEC-24, SEC-36, SEC-44).
- Respuestas del chatbot a los intentos de prompt injection.
- Informe anterior: Sprint 8.